



File No.: EXP202303565

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On May 6, 2024, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against PILLOW HOTELS, S.L. (hereinafter, the respondent), through the Agreement that is transcribed:

<<

File No.: EXP202303565

AGREEMENT TO INITIATE SANCTIONING PROCEEDINGS

From the actions carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on 07/02/2023. The complaint is directed against PILLOW HOTELS, S.L., with NIF B66964255 (hereinafter, the respondent). The reasons for the complaint are as follows: the claimant states that she made a reservation at the Bilbao accommodation "Irala, by Pillow," through booking.com. She indicates that a few days before the trip, she received a WhatsApp message in which a person identifying herself as the hotel director addressed her by her full name and requested confirmation of the reservation, providing her with a fraudulent link to enter her card details, which she did not do. She states that she contacted the hotel to confirm the fraud and was informed that they were already aware of other similar cases.

Screenshots of the WhatsApp conversation in which the impersonation of the accommodation and attempted fraud occurred are provided.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), on 22/03/2023, the complaint was forwarded to the respondent for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) through electronic notification, was not acknowledged by the responsible party within the availability period, being understood as rejected in accordance with the provisions of Article 43.2 of the LPACAP on 02/04/2023, as stated in the certificate in the file.

Although the notification was validly carried out by electronic means, with the procedure considered completed in accordance with the provisions of Article 41.5 of the LPACAP, an informational copy was sent by postal mail, which was duly notified on 04/04/2023. In this notification, the obligation to communicate electronically with the Administration was reminded, and information was provided on the means of access to such notifications, reiterating that, henceforth, notifications would be made exclusively by electronic means.

THIRD: On 07/05/2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the claimant was admitted for processing.

FOURTH: The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in

Title VII, Chapter I, Section Two, of the LOPDGGD, having knowledge of the following points:

The present investigative actions have focused on the points that will be developed below.

Point 1: Regarding the investigated company.

The respondent is a limited liability company of Spanish nationality. According to the data available in AXESOR for the year 2022, it is a SME, with 13 employees and a sales volume of less than one million euros. No previous files related to breaches by this entity have been found in Sigrid.

The entity MD MANAGEMENT, S.L., acts as the parent company of the group to which the respondent belongs, being a company with a single employee and a sales volume of less than one million euros, according to AXESOR for the year 2022. No previous files related to breaches by this entity have been found in Sigrid either.

The entity RAPINFORMES ON LINE, S.L., has acted as a representative.

Point 2: Verification of the claimed facts.

As a starting point, efforts have been made to verify the claimed facts and the details of the incident.

For this purpose, requests have been made to the respondent, the claimant, and the provider of the booking platform Booking.com.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/32

2.1. Chronology of Events.

The chronological order of the events, obtained from the information provided, is as follows:

- The claimant made a reservation on 05/01/2023 at the accommodation of the respondent. The reservation was made through the external provider platform Booking.com. The claimant received an email that day from Booking.com, confirming their reservation and providing basic details. The reservation was for the dates from 08 to 10/02/2023.
- According to Booking.com, regarding the account of the respondent on their platform, "the first malicious attempt occurred on 20/01/2023." It has not been possible to delve into the specific attack suffered, although it is indicated that it would involve phishing aimed at obtaining access credentials. Consulting the breach registry maintained by the Technological Innovation Division of the AEPD, no specific breach notification from Booking.com has been located, although there are records from that time of similar cases where hotel establishments have been affected by the compromise of their account on the platform due to phishing attacks. Additionally, information available in IMI (Internal Market Information System) has been consulted. No entry related to this breach has been found, although there is a prior entry of a similar type, in which Spain is listed as the interested supervisory authority (entry no. ***ENTRY.1).
- The respondent indicates that on 30/01/2023, they requested their IT department to change the passwords for the email accounts.
- On 03/02/2023, the attempted fraud and impersonation of the accommodation, which is the subject of the complaint filed, occurred. In the screenshots provided by the claimant, the attempt at fraud can be verified through the type described in the complaint: a person claiming to be the hotel director requests confirmation of the reservation and sends a link to a payment gateway (**URL.1). The number from which the claimant was contacted was ***PHONE.1. According to the respondent, the number ***PHONE.2 was also used for these purposes.
- The claimant contacted the accommodation on the same day, 3 February. They state that they called by phone and sent an email alerting about the incident that occurred. A copy of the email conversation is provided. The respondent replied on 3 February, requesting screenshots of the alleged fraud, which were subsequently sent.
- The claimant states that once they arrived at the accommodation, which can be inferred from the above to be on 08/02/2023, the person who attended to them at the reception informed them that "they knew that a leak had occurred and were investigating the source."
- According to Booking.com, in March 2023, the accommodation's account on their platform was compromised for security reasons.

- Subsequently, the claimant received an email from Booking.com on 07/03/2023 regarding their reservation. A copy of this email is provided.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
4/32

This email indicates that some clients were receiving suspicious calls or emails attempting to impersonate them, Booking.com, as well as the accommodations using the platform. The email includes a series of security recommendations to prevent scams, as well as links in case they have been victims of any type of fraud of this nature.

-

Following subsequent requests for information from the defendant, information was sent indicating that a second breach and attempt at fraud with similar characteristics occurred in August 2023. Analyzing the information provided, this breach may have occurred on August 17, and based on the statements provided by the defendant, it happened due to the compromise of the access credentials to their account on the Booking.com platform.

Point 3. Operation of the reservation system.

To delve deeper into the incident, efforts have been made to study and understand the operation of reservations, from the moment a client makes a reservation through the Booking.com platform until the data reaches the hotel. Since the incident occurred before the stay was made, the leak must have happened in one of the elements involved in the management of reservations.

The defendant states that when a client makes a reservation, they receive an email in the reception inbox containing the client's details, including their name, surname, contact information (phone number), and the dates of the stay. They provide a sample email. In this email, it is noted that it comes from WuBook (***EMAIL.1). This is a platform for managing reservations, which can act as an intermediary between Booking.com and the accommodation.

In relation to WuBook, the subscription contract for this service has been provided. This contract is signed between MasterYield S.L. and the claimant in the form of software rental, forming part of the set of services offered by the MasterYield PMS hotel management system.

It has not been possible to delve into the use that the defendant makes of this platform; based on the information available about this provider on the Internet, the expected use would be for managing reservations, integrating with the data registered on Booking.com as an external portal for clients. It has not been possible to verify what existing security measures are in place or the retention periods for the information stored there.

From Booking.com, the information stated about the operation of reservations is as follows: Once a client has made a reservation on their platform, their data is processed by Booking.com and the accommodation provider, as well as potentially their connectivity provider. Booking.com transfers the most relevant data to the accommodation, which may vary depending on the type of reservation. According to the information provided, this would include the client's name, contact details, payment information, names of accompanying persons, and preferences they may have specified when making the reservation. In certain cases, additional information is provided.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
5/32

additional information regarding the client's history: whether they have previously stayed at that accommodation, completed and canceled reservations, misconduct notices, and reviews issued. The channel for transferring this information is not specified. In any case, according to the information provided by Booking.com, which will be developed later, this information would be accessible from their platform using the user account that the accommodation has. It is not stated that the accommodation has its own infrastructure where the information is stored, beyond the corporate email.

From the statements made, the management of reservations is carried out through these two tools: the Booking.com platform and email.

Point 4: Analysis of the gaps.

4.1. Origin of the first gap.

It has not been possible to determine the exact origin of the gap. The party being claimed against states that they are unaware of it. They indicate, "I thought about changing the reception email password and it stopped working, so it must have been some fraudulent link that a receptionist opened," which could suggest a case of phishing.

Collaboration has been requested from Booking.com to try to clarify the facts, through their subsidiary in Spain. Booking.com B.V., the parent company of the Booking.com group, is registered and has its headquarters in the Netherlands. As indicated in the legal information on their portal, the management of the platform corresponds exclusively to that entity: "Booking.com B.V. (the company behind Booking.com™) is registered and has its headquarters in Amsterdam, Netherlands, from where it offers an online accommodation booking service through its website (...) The subsidiary companies do not offer the Service and do not own, operate, or manage the Website or any other website."

They state that none of their systems have been compromised and transfer the responsibility for the incidents to the accommodations, indicating that they are frequently victims of phishing attacks. As a result of these attacks, unauthorized access to the accommodation's account on the Booking.com platform occurs, from where customer information for those with reservations there can be consulted.

Booking.com indicates in their response that it is a common practice for accommodations to be compromised by phishing attacks, with attackers obtaining their credentials and having the ability to act on their behalf. They mention that they are aware of different methods used by attackers:

"attackers send a 'phishing link' requesting to click on it. Booking.com is aware that some accommodation providers clicked on this link and downloaded a malicious file that infected their device with malware. This malware allowed the attackers to access the accommodation provider's computer."

Once the credentials for their platform are obtained, attackers would have access to customer data and could contact them through other channels, such as WhatsApp.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/32

They state that they are unaware of the exact number of affected individuals, as these incidents are external to them. They indicate that "we have received reports of 11,244 affected reservations in Spain during this year 2023." It has not been possible to delve into the types of incidents they refer to, whether it is specific to this investigated accommodation or generally for all accommodations in Spain that use their platform.

In relation to this specific case, Booking.com, as noted in the timeline, states that the first security incident involving the account of the party being claimed against occurred on 20/01/2023. No further details are provided regarding the type of incident. They state that "it was confirmed that the accommodation account was compromised in March 2023," but no additional information has been provided on this aspect either.

The incident being claimed occurred between these two events, so it can be presumed that there was a direct relationship and the origin of the breach may have been a violation and unauthorized access to the accommodation's account or its corporate email, considering that the change of password for at least the email resolved the incident, according to the party being claimed against.

4.2. Origin of the second breach.

As indicated, a second breach of similar characteristics occurred in August 2023. It is not possible to determine its origin, but in this case, based on the statements provided, it would focus on the corporate account of the accommodation on the Booking.com platform.

The password for this platform would have been compromised and presumably exploited to obtain customer information. The party being claimed against states the following in this regard: "we changed the Booking password several times, most of which caused Booking itself to log us out of the website

and ask us to set a new password again, I don't know if it was due to Booking itself or because the hacker wanted to regain control. We were in this situation for several hours, and I changed the password no less than 7 or 8 times."

The party being claimed against shifts the responsibility for this second breach to Booking.com. They provide a communication from Booking.com in which this entity states that a security breach related to the accommodation's account on its platform (Extranet) has occurred: "we have followed up on your report of suspicious activity on your Extranet Account, we regret to inform you that our Security team has confirmed a breach has occurred." From the content of the message, it cannot be determined the origin of this breach, whether it is indeed due to an incident at Booking.com as the accommodation claims or not.

4.3. Volume of affected individuals.

The party being claimed against has stated that a total of 24 individuals may have been affected by the first breach, which is the initial subject of this investigation. They provide an Excel document with the customers who had reservations during those dates, among whom is the claiming party.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/32

Regarding the second incident, which occurred in August 2023, the party being claimed against has not provided the number of customers affected by the breach. Based on the information provided, it would involve several dozen: "all the reservations (dozens, if not more)."

4.4. Type of affected data.

The affected data has included, at a minimum, name, surname, contact details (phone, email), and reservation dates. Since it has not been possible to determine the point at which the breach occurred, it is not possible to specify this information.

The claiming party states the following: "Name and surname, date of stay, type of room, amount, etc." Assuming that the accommodation's account on the Booking.com platform was compromised, as previously analyzed, the affected data could have been greater. According to Booking.com, if this account had been affected, potential attackers could have access to:

- Name and surname.
- Phone number.
- Email address alias.
- Reservation number.
- First and last reservation date.

According to the Record of Processing Activities provided, related to the processing concerning customers, the total data involved would be:

- ID card or tax identification number
- Name and surname
- Postal or email address
- Phone
- Manual signature
- Personal characteristics
- Social circumstances
- Commercial information
- Economic, financial, and insurance data
- Transactions of goods and services

Point 5: Informative communication of the incident.

After the inquiries made, efforts have been made to confirm the communications made by the claiming party informing about the breach that occurred, both to the affected customers and the reason for not having informed this Agency.

It is not possible to verify that any proactive communication was made to the customers affected by the

incident of January/February 2023, among whom was the claiming party. They state that customers who called them regarding this issue were informed.

According to the incident record document provided, it was determined that it was not necessary to notify either the Control Authority or

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/32

the interested parties: “It is unlikely that the security breach poses a risk to the rights and freedoms of individuals, therefore, in accordance with Articles 33.1 and 34.1 of the GDPR, it is not mandatory to notify the supervisory authority or communicate it to the interested parties.”

For the incident in August 2023, the responding party does state that they contacted the customers. A screenshot of one of the messages sent on 17/08/23 via Booking.com messaging is provided, in which the responding party informed about the incident and alerted to the fraudulent practice. In this message, the accommodation states: “our account has been hacked.” It cannot be verified that all potential affected parties were informed or that the communication was made in a timely manner.

There is no general publication on the hotel’s website warning about these incidents, in case communication was made through that medium.

Regarding the communication of these breaches to this Agency, there is no record of any notification in this regard.

Point 6: Security measures implemented.

6.1. Measures prior to the breach.

In the context of the transfer, the following documentation has been provided, focused from a regulatory perspective:

- Record of Processing Activities.
- Record of security breaches.
- Risk analysis.
- Technical and organizational measures.
- Compliance report.

This documentation contains the logos of the parent company, MD MANAGEMENT, S.L., and the representative, RAPINFORMES ON LINE, S.L., with the responding party (PILLOW HOTELS, S.L.) not being listed. The tax name of the data controller is indicated as: MD MANAGEMENT 2010 S.L. The prior measures, as stated by the responding party in the record of security breaches, were as follows:

- Data protection and security policies.
- System updates.
- Software updates.
- Equipment updates.
- Record of security breaches.
- Periodic audits.
- Backup system.

No documentary evidence of these measures or further details have been provided.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/32

In the risk analysis, corporate email is addressed. It is indicated that there is no control or record of unauthorized access to the application and a low risk is estimated. There is no mention of the management of the account on the Booking.com platform in this analysis. Phishing risks are not considered to exist.

The proposed measures, as detailed in the provided documentation, are oriented towards email and focus on ensuring that messages are sent encrypted. It is indicated that there are anti-phishing systems.

6.1.1. Employee training.

Training actions prior to the breach in the area of cybersecurity and data protection have been requested.

Certificates from December 2022 have been provided for the completion of a course titled "Organic Law on Data Protection and Guarantee of Digital Rights," for a total of 5 individuals whom the responding party claims are their employees. This information is complemented by a presentation of a data protection training prepared by RAPINFORMES ON LINE, S.L.

Regarding the employees, the Social Security registry linking them to the company is provided. This registry includes another list of workers, with 4 of these 5 individuals coinciding, while some others are listed for whom no training certificate has been provided. This registry is listed under the business name VA OPCO SOCIEDAD LIMITADA. It is noted that, according to AXESOR, their workforce in 2022 was 13 employees. No information has been provided regarding the job positions held by these individuals, particularly whether they are the ones exclusively managing the email inbox and the account on the Booking.com platform.

6.2. Measures adopted subsequently.

The measures to remedy the first breach, as stated by the responding party in the provided record of security breaches, were as follows:

- Data protection and security policies.
- System updates.
- Software updates.
- Equipment updates.
- Periodic audits.
- Backup system.
- Update of the record of security breaches with details related to this personal data breach.

No evidence of their effective implementation has been provided. It is highlighted that, except for the update of the breach record, the rest of the measures were also listed as prior security measures.

Regarding the record of security breaches: There is a single record, related to the breach subject to the claim. The date of the breach and detection is indicated as 20/04/2023 (on this date, a response to the transfer was given). As affected data, only the phone number is listed, and there is no record of the number of interested parties. It is indicated in the description of the incident: "...it is said that they contacted the hotel."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/32

to confirm the fraud and that they were informed that they were already aware of other similar cases." According to this record, the breach was deemed resolved on 21/07/2023.

In addition to the information provided in the aforementioned document, according to the statements made, further operational measures were taken subsequently, mainly the change of credentials.

For the first breach, the responding party states that on 30/01/2023 their IT department modified the passwords for the email accounts and, after changing the access password for the reception email, the incident was resolved. Regarding the reason for this change, they state: "They accessed the company email and proceeded to change the password," without providing further detail. It is noteworthy that the attempted fraud against the claimant occurred later, on 03/02/2023, and it was on this date that they contacted the accommodation. It is not confirmed whether the password for their account on the Booking.com platform was changed in this first case.

They state that they notified their management, Booking.com, their commercial department, and attempted to file a complaint with the Ertzaintza. No documentation is provided in this regard.

Regarding the second reported incident, the actions taken have been similar. The responding party

states that the password for the Booking.com platform was changed repeatedly: “We changed the Booking password several times, (...) We were like this for several hours, and I changed the password no less than 7 or 8 times.”

Additionally, they state that for this second incident they conducted an analysis of their computer systems and email, without detecting any malware.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

First obligation breached: infringement of Article 5.1.f) of the GDPR

In accordance with the provisions of Article 4.1 of the GDPR, the processing of personal data is confirmed, as the responding party carries out, among other things, the collection and storage of personal data, primarily of its customers.

The entity carries out this activity in its capacity as the data controller, as it is the one that determines the purposes and means related to the processing of personal data, by virtue of Article 4.7 of the GDPR.

Moreover, the data controller must also be responsible for applying the technical and organizational measures that ensure the security of personal data when carrying out the processing. And must be able to demonstrate compliance with the GDPR and the LOPDGDD.

In this case, the facts materialize in the access to personal data by third parties, as a consequence of a security breach resulting from the claimant making a reservation at the establishment of the responding party, which could imply a violation of the regulations on data protection.

Article 5.1.f) “Principles relating to processing” of the GDPR states:

“1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures (‘integrity and confidentiality’).”

(...)

The documentation in the file provides clear indications that the entity may have violated Article 5.1.f) of the GDPR, principles relating to processing, by failing to adequately guarantee the confidentiality of personal data as a result of the security breach that occurred.

This duty of confidentiality must be understood as aimed at preventing unauthorized data leaks by the data subjects.

It is noted that the claimant received on 03/02/2023, via the social network WhatsApp, a message supposedly from the accommodation where they had made a reservation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/32

reservation to be enjoyed between 8 and 10/02/2023; in the aforementioned message, a person claiming to be the director of the accommodation requests confirmation of the reservation and sends a link to a payment gateway: ***URL.1, where banking details are requested, which the claimant refuses

to provide. The message identifies the claimant through: name and surname and phone number. In the received WhatsApp message, the following appears:

***PHONE.1

Hello, claimant

My name is B.B.B.

You booked our apartments on

Booking.com

I am the Director of the responding party

We look forward to meeting you

But you should know that I have to finalize

your reservation

Please let me know if your reservation is

updated so that I can confirm it

Responding party B.B.B.

Once the reservation is confirmed by the claimant, a second message is received:

***PHONE.1

Okay,

Please follow this web link to confirm your reservation

***URL.2

Your payment will be processed according to the terms of your agreement with

Booking.com

You have a free cancellation option.

So don't worry about the

cancellation.

Thank you for your understanding

The claimant sent an email to the responding party

reporting the incident:

"I received a WhatsApp message impersonating you (attached screenshots). They knew my full name and my phone number, which indicates that you have a security breach.

I urge you to report the impersonator and, more importantly, ensure that you handle your customers' data securely. Please keep me informed of your actions regarding this."

Although the origin of the breach is unknown, the responding party acknowledges that the origin of the message directed to the claimant may have been caused by negligent action on their part: "I thought of changing the reception email password and it stopped working, so it must have been some fraudulent link that a receptionist opened," resulting in a breach of their

accounts: "They accessed the company's email," and the Booking.com platform has indicated that in March 2023, the accommodation account was compromised for security reasons.

Additionally, according to the claimant, the reception of the accommodation informed them that "they knew there had been a leak and were investigating the origin."

The number of people affected by this first breach totals 24 individuals, with a document provided containing the list of affected customers who had reservations during those dates, including the claimant.

Subsequently, in August 2023, a second security breach of similar characteristics occurred, the origin of which has also not been determined.

In this security incident, although the number of affected customers has not been provided, the information suggests that it would be a fairly high number, "all the reservations (dozens if not more)."

On the other hand, regarding the affected data, at least the following would be included: name, surname, and contact details (phone, email).

In light of the above and without prejudice to the outcome of the investigation of this procedure, it is considered that the responding party may have violated the principle of confidentiality of data, enshrined in Article 5.1.f) of the GDPR, an infringement classified in Article 83.5.a) of the GDPR.

III

Classification for the infringement of Article 5.1.f) of the GDPR

In accordance with the evidence available and without prejudice to the results of the investigation, it is considered that the responding party did not adequately guarantee the confidentiality and integrity of personal data.

The infringement attributed to the entity is classified in Article 83.5 a) of the GDPR, which states that the infringement of "the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9" is punishable, according to paragraph 5 of the aforementioned Article 83 of the cited Regulation, "with administrative fines of up to €20,000,000 or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount."

The LOPDGDD in its Article 71, Infringements, states that: "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

And in its Article 72, it considers for the purposes of prescription that: "Very serious infringements:

1. According to what is established in Article 83.5 of Regulation (EU) 2016/679, the infringements that are considered very serious and will prescribe in three years are:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/32

assume a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.

(...)

IV

Proposal for sanction for the infringement of Article 5.1.f) of the GDPR

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, compliance with those measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement. In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, "Sanctions and corrective measures," establishes that:

"2. According to the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The continued nature of the infringement.

b) The connection of the infringer's activity with the processing of personal data.

c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject."

- In accordance with the transcribed provisions, and without prejudice to the outcome of the instruction of the procedure, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement of Article 5.1.f) of the GDPR, classified in Article 83.5.a) of the GDPR for which the claimed party is responsible, an initial assessment considers the following factors to be concurrent:

The nature, gravity, and duration of the infringement; the facts revealed affect a basic principle regarding the processing of personal data, such as confidentiality and integrity, which the regulation penalizes with the utmost severity; in this case, as a consequence of the security incident, access to the personal data of the claiming party by the claimed party was enabled, which was not authorized, with the damages that this may entail.

The intentionality or negligence in the infringement. There is a serious lack of diligence in complying with the obligations imposed by data protection regulations, allowing cybercriminals to access personal data, violating confidentiality and integrity on two occasions due to the established breaches; in this regard, the SAN of 17/10/2007 can be cited, which, although issued before the GDPR came into force, its ruling is perfectly extrapolable to the case we are analyzing. The ruling, after stating that entities whose activities involve continuous processing of customer and third-party data must observe an adequate level of diligence, specified that "(...). the Supreme Court has understood that there exists...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/32

negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, particular emphasis must be placed on the professionalism or lack thereof of the individual, and there is no doubt that, in the case currently examined, when the activity of the appellant involves constant and abundant handling of personal data, it is essential to insist on the rigor and exquisite care to comply with the legal provisions in this regard" (Article 83.2, b) of the GDPR).

The activity of the allegedly infringing entity is linked to the processing of personal data of both clients and third parties. In the activity of the claimed entity, the processing of personal data is essential, and given its business purpose, the significance of the conduct subject to this claim is undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

The turnover of the claimed party; it is a small company with a turnover in the fiscal year 2022 of €844,498 (Article 83.2, k) of the GDPR).

For the purposes of deciding on the imposition of the fine and its amount, in accordance with the

evidence available and without prejudice to what results from the instruction of the procedure, taking into account the criteria of Article 83.2 of the GDPR regarding the infringement committed, violation of Article 5.1.f) of the GDPR, it is considered appropriate to set a sanction of €3,000.

V

Second obligation breached: infringement of Article 32.1 of the GDPR

Article 32 of the GDPR "Security of processing" establishes that:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
 - b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
 - c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
 - d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.
2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/32

personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.

3. Adherence to a code of conduct approved pursuant to Article 40 or to a certification mechanism approved pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The data controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller, unless required to do so by Union or Member State law.

The GDPR defines personal data security breaches as "all breaches of security that result in the accidental or unlawful destruction, loss, alteration of, or unauthorized communication or access to personal data transmitted, stored, or otherwise processed."

The documentation in the file evidences the violation of Article 32.1 of the GDPR, as a result of the lack of appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing.

It should be noted that the GDPR in the aforementioned provision does not establish a list of security measures applicable according to the data being processed, but rather states that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of the technical and organizational measures should be made considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification processes (not audits), evaluation, and assessment of the effectiveness of the measures. In any case, when assessing the adequacy of the level of security to the risk, particular consideration

shall be given to the risks presented by the processing of data, as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states that:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/32

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may in particular cause physical, material, or immaterial damage.”

In this case, it is evident that the security measures that the respondent had in place regarding the data it processed were neither appropriate nor adequate to ensure the security of personal data at the time the aforementioned incidents (breaches) occurred.

As also noted in Recital 39:

“...Personal data must be processed in a manner that ensures adequate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and the equipment used in the processing.”

According to the respondent, measures were taken to remedy this first breach; however, it is not evidenced that these measures were adopted, except for the breach register, as the enumerated measures were already in place prior to the breach incident and, due to the outcome that occurred, they were neither effective nor sufficient. And regarding the breach register, only the first one is documented, not the second, and in the description of the incident, it is indicated, referring to the claimant, “says that they contacted the hotel to confirm the fraud and that they were informed that they were already aware of other similar cases.”

The risk analysis document also does not include control or recording of unauthorized access to the application, nor does it address the management of the account on the Booking.com platform, not considering phishing risks.

As for the second incident, of similar characteristics, it occurred in August 2023. The respondent has stated: “We changed the Booking password several times, most of which Booking itself kicked us off the website and asked us to set a new password, I don’t know if it was due to Booking itself or because the hacker wanted to regain control. We were like this for several hours, and I changed the password no less than 7 or 8 times.”

It should be noted that security measures are key to guaranteeing the fundamental right to data protection, as it is not possible to ensure this right if confidentiality, integrity, and availability of personal data cannot be guaranteed. To ensure these security factors, both technical and organizational measures that are adequate are necessary.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/32

The adequacy of the security level to the risk must be evaluated by the responsible party and reconsidered periodically based on the results obtained, taking into account -among other factors- the risks that the processing may present as a consequence of the unauthorized communication of such

data.

The technical and organizational security measures that must be applied are those relevant to respond to the existing risk, considering, among other factors, the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of probability and severity for the rights and freedoms of the data subjects.

One of the requirements established by the GDPR for controllers and processors conducting activities involving personal data processing is the necessity to carry out a risk analysis of information security in order to establish security and control measures aimed at complying with the principles of protection by design and by default that guarantee the rights and freedoms of individuals.

The responsibility of the claimant is determined by the personal data breaches revealed, as they are responsible for making decisions aimed at effectively implementing the appropriate technical and organizational measures to ensure a level of security adequate to the risk to safeguard the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident. In this regard, the measures were not appropriate, regardless of the personal data breach that occurred.

This lack of security measures that causes the infringement of Article 32.1 constitutes an infringement in itself, considered independently of the detected security incidents and personal data breaches that occurred.

As specified in the Supreme Court ruling of 15/02/2022: "In obligations of means, the commitment undertaken is to adopt the technical and organizational means, as well as to deploy diligent activity in their implementation and use aimed at achieving the expected result with means that can reasonably be classified as suitable and sufficient for its achievement; therefore, they are referred to as 'diligence' or 'behavior' obligations."

In its second foundation, it states: "(...) the issue of casational interest consists of determining whether the infringements of the Data Protection Law due to failures in security measures (...) should be examined in light of the result and, (...) regardless of the means and preventive measures that may have been adopted. (...)"

And in its third foundation: "The obligation to adopt the necessary measures to guarantee the security of personal data cannot be considered an obligation of result, which implies that once a personal data leak occurs to a third party, there is liability regardless of the measures adopted and the activity carried out by the data controller or processor."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

20/32

(...)"

Therefore, in accordance with the above, it is estimated that the respondent would be presumably responsible for the infringement of the GDPR: the violation of Article 32.1, an infringement classified in its Article 83.4.a) of the GDPR.

VI

Classification of the infringement of Article 32.1 GDPR

The violation of Article 32 of the GDPR is classified in Article 83.4.a) of the aforementioned GDPR in the following terms:

"4. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43.

(...)"

The LOPDGDD in its Article 71, Infringements, states that: "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For its part, the LOPDGDD in its Article 73, for the purposes of prescription, qualifies as “Serious Infringements”:

According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.

(...)”

VII

Proposal for sanction for non-compliance with Article 32.1 GDPR

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/32

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
 - b) the intentionality or negligence in the infringement;
 - c) any measures taken by the data controller or processor to mitigate the damage and harm suffered by the data subjects;
 - d) the degree of responsibility of the data controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
 - e) any previous infringement committed by the data controller or processor;
 - f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
 - g) the categories of personal data affected by the infringement;
 - h) the manner in which the supervisory authority became aware of the infringement, in particular whether the data controller or processor notified the infringement and, if so, to what extent;
 - i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, the compliance with such measures;
 - j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
 - k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.
- In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, “Sanctions and corrective measures,” establishes that:

“2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/32

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) To have, when not mandatory, a data protection officer.

h) The voluntary submission by the responsible party or processor to alternative dispute resolution mechanisms, in those cases where there are disputes between them and any interested party.”

- In accordance with the transcribed provisions, and without prejudice to what results from the instruction of the procedure, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement typified in Article 32.1 of the GDPR, classified in Article 83.4.a) of the GDPR for which the respondent is held responsible, the following factors are initially considered concurrent:

The nature and severity of the infringement; the facts revealed affect an essential element of the processing of personal data, namely the security of such data; it must be considered that the measures implemented were not suitable to ensure an adequate level of security in relation to the risk; measures that were not appropriate and that are key to guaranteeing the fundamental right to data protection, the infringement of which the regulation penalizes severely.

The number of affected individuals, as according to the respondent, the number of affected individuals may have been 24, due to the first breach, and a second, with very similar characteristics, occurring on 17/08/2023, although the number of affected clients could not be determined, the information provided suggests that it would be a quite high number, “all the rsvs (dozens if not more).”

Level of harm and damages suffered: although it is not evidenced that harm was caused to the claimant, this does not prevent the rest of those affected by the breaches from having suffered some type of damages (Article 83.2.a) of the GDPR).

Intent or negligence in the infringement. There is a serious lack of diligence in complying with the obligations imposed by the regulations on data protection, due to the inadequate measures implemented; in this regard, the SAN of 17/10/2007 can be cited, which, although issued before the GDPR came into force, its ruling is perfectly extrapolable to the case we are analyzing. The ruling, after referring to the fact that entities whose activities involve continuous processing of customer and third-party data must observe an adequate level of diligence, specified that “(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on the rigor and exquisite care to comply with the legal provisions in this regard.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/32

The activity of the allegedly infringing entity is linked to the processing of personal data of both clients and third parties. In the activity of the claimed entity, the processing of personal data is essential; therefore, given its purpose and business volume, the significance of the conduct subject to this claim is undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

For the purpose of deciding on the imposition of the fine and its amount, in accordance with the evidence available and without prejudice to what results from the instruction of the procedure, taking

into account the criteria of Article 83.2 of the GDPR regarding the infringement committed, violation of Article 32.1 of the GDPR, it is considered appropriate to set a sanction of 2,000 euros.

VIII

Third obligation breached: infringement of Article 33.1 of the GDPR

Article 33 of the GDPR, Notification of a personal data breach to the supervisory authority, establishes that:

“1. In the case of a personal data breach, the data controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, no later than 72 hours after having become aware of it, unless the breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by reasons for the delay.

2. The processor shall notify the controller without undue delay of any personal data breaches of which it becomes aware.

3. The notification referred to in paragraph 1 shall, at a minimum:

a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects affected, and the categories and approximate number of personal data records concerned;

b) communicate the name and contact details of the data protection officer or other contact point where more information can be obtained;

c) describe the likely consequences of the personal data breach;

d) describe the measures taken or proposed by the data controller to remedy the personal data breach, including, where appropriate, the measures taken to mitigate the possible adverse effects.

4. If it is not possible to provide the information simultaneously, and to the extent that it is not possible, the information shall be provided in phases without undue delay.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/32

5. The data controller shall document any breach of personal data security, including the facts related to it, its effects, and the corrective measures taken. Such documentation will allow the supervisory authority to verify compliance with the provisions of this article.

The obligation to notify the supervisory authority of breaches or failures that may affect personal data applies to any data controller, underscoring the importance of all entities knowing how to manage them.

In this regard, Recital 87 states that:

“It must be verified whether all appropriate technological protection has been applied and whether appropriate organizational measures have been taken to determine immediately if a breach of personal data security has occurred and to inform the supervisory authority and the data subject without delay. It must be verified that the notification has been made without undue delay, taking into account, in particular, the nature and severity of the breach of personal data security and its consequences and adverse effects for the data subject. Such notification may result in an intervention by the supervisory authority in accordance with the functions and powers established by this Regulation.”

For its part, this Agency has indicated the following in its Guide for the notification of personal data breaches (see June 2021), in section IV, it states:

“The notification of a personal data breach to the Supervisory Authority in accordance with Article 33 of the GDPR is the responsibility of the data controller. The controller may authorize a natural person, representative, or entity exercising its representation to make the notification of the personal data breach to the Supervisory Authority.

The processor that has been subject to the personal data breach may only notify on behalf of the controller if this is established in a contract or legal link of a similar nature. In any case, the data controller must be informed in advance about the occurrence of the personal data breach and all

relevant details as established in Article 33.2 of the GDPR.”

It should be noted that once knowledge of the security breach has been obtained, the GDPR establishes that the data controller shall notify the competent supervisory authority without undue delay and, if possible, no later than 72 hours after becoming aware of it, unless it is unlikely that the breach of security constitutes a risk to the rights and freedoms of natural persons.

The GDPR also establishes the cases in which a personal data breach must be communicated to the affected individual, specifically when it is likely that the breach of personal data poses a high risk to the rights and freedoms of natural persons.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

25/32

Both the notification to the competent supervisory authority and the communication to the affected individual are obligations of the data controller, although they may delegate the execution of the same to other figures, such as the processor, provided that this is foreseen in the corresponding service contract.

Therefore, the controller had the obligation to notify the supervisory authority of the personal data breaches that occurred, from which it follows that the conduct of the respondent constitutes a violation of Article 33.1 of the GDPR, an infringement classified in its Article 83.4.a) of the same legal text.

IX

Classification of the infringement of Article 33.1 GDPR

The violation of Article 33 of the GDPR is classified in Article 83.4.a) of the aforementioned GDPR in the following terms:

“4. The infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43.
(...)”

The LOPDGDD in its Article 71, Infringements, states that: “Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For its part, the LOPDGDD in its Article 73, for the purposes of prescription, qualifies as “Serious Infringements:

According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

r) The failure to notify the data protection authority of a personal data security breach in accordance with the provisions of Article 33 of Regulation (EU) 2016/679.

(...)”

X

Proposed sanction for non-compliance with Article 33.1 GDPR

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

26/32

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article

for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures referred to in Article 58, paragraph 2, have previously been ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct pursuant to Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.

In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, "Sanctions and corrective measures," establishes that:

"2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/32

- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party could have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) To have, when not mandatory, a data protection officer.
- h) The voluntary submission by the responsible party or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party."

- In accordance with the transcribed provisions, and without prejudice to what results from the instruction of the procedure, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement classified in Article 33.1 of the GDPR, classified in Article 83.4.a) of the GDPR for which the claimed party is responsible, an initial assessment considers the following factors to be concurrent:

The intentionality or negligence in the infringement. There is a serious lack of diligence in complying with the obligations imposed by the regulations on data protection; in this regard, the SAN of

17/10/2007 can be cited, which, although issued before the entry into force of the GDPR, its pronouncement is perfectly extrapolable to the case we are analyzing. The ruling, after referring to the fact that entities whose activities involve continuous processing of data from clients and third parties must observe an adequate level of diligence, specified that "(...). the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on the rigor and exquisite care to comply with the legal provisions in this regard."

The activity of the allegedly infringing entity is linked to the processing of personal data of both clients and third parties. In the activity of the claimed entity, the processing of personal data is essential, so given its object and business volume, the significance of the conduct subject to this claim is undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

For the purpose of deciding on the imposition of the fine and its amount, in accordance with the evidence available and without prejudice to what results from the instruction of the procedure, taking into account the criteria of Article 83.2 of the GDPR regarding the committed infringement, violation of Article 33.1 of the GDPR, it is considered appropriate to set a sanction of 2,000 euros.

XI

Adoption of measures

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/32

If the violations are confirmed, it may be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...". The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR. Therefore, it would be considered appropriate to order the respondent, within a period of six months from the finality of the sanctioning resolution that is issued in any case, to adjust the processing activities subject to this procedure to the applicable regulations. The text of this agreement establishes what the facts have been that led to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the one that fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD. The measures to be adopted are indicated as follows: the implementation of technical and organizational measures that ensure data security and prevent access to the same by third parties in accordance with the provisions of Articles 5.1.f) and 32.1 of the GDPR, as well as establishing in a verifiable manner those that ensure compliance with the provisions of Article 33.1 of the GDPR. It is warned that failure to comply with the order imposed by this body may be considered an administrative violation in accordance with the provisions of the GDPR, classified as a violation in its Articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in light of the above,

By the Director of the Spanish Agency for Data Protection,

IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against PILLOW HOTELS, S.L., with NIF B66964255,

- For the alleged violation of Article 5.1.f) of the GDPR, classified in Article 83.5.a) of the GDPR.
- For the alleged violation of Article 32.1 of the GDPR, classified in Article 83.4.a) of the GDPR.
- For the alleged violation of Article 33.1 of the GDPR, classified in Article 83.4.a) of the GDPR.

SECOND: TO APPOINT R.R.R. as Instructor and S.S.S. as Secretary, indicating that either of them may be recused, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the complaint filed by the complainant and its documentation, the documents obtained and generated by the Inspection Services that make up the file.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, and Article 58.2.b) of the GDPR, the sanctions that may correspond for the violation of Articles 5.1.f), 32.1, and 33.1 of the GDPR would be €3,000, €2,000, and €2,000 (three thousand euros, two thousand euros, two thousand euros) respectively, without prejudice to what results from the instruction.

FIFTH: TO NOTIFY this Agreement to PILLOW HOTELS, S.L., with NIF B66964255, expressly informing them of their right to a hearing in the procedure and granting them a period of TEN WORKING DAYS to submit allegations and propose the evidence they deem appropriate. In their written allegations, they must provide their NIF and the procedure number that appears in the heading of this document.

If no allegations are made within the stipulated period regarding this initiation agreement, it may be considered a proposal for resolution, as provided in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

In accordance with the provisions of Article 85 of the LPACAP, if the sanction to be imposed is a fine, they may acknowledge their responsibility within the period granted for submitting allegations to this initiation agreement; this will entail a reduction of 20% of the sanction to be imposed in this procedure. With the application of this reduction, the total sanction would be established at €5,600, resolving the procedure with the imposition of this sanction.

Similarly, they may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will entail a reduction of 20% of its amount. With the application of this reduction, the total sanction would be established at €5,600, and its payment will imply the termination of the procedure, without prejudice to the measures that may be imposed.

The reduction for the voluntary payment of the sanction is cumulative to that which corresponds to be applied for the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to submit allegations to the initiation of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the total amount of the sanction would be established at €4,200.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/32

In any case, the effectiveness of either of the two reductions mentioned will be conditioned upon the withdrawal or renunciation of any administrative action or appeal against the sanction.

In the event that you choose to proceed with the voluntary payment of any of the amounts indicated above (5,600 or 4,200 euros), you must make the payment by depositing it into account number ES00 0000 0000 0000 0000 opened in the name of the Spanish Agency for Data Protection at Banco CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which you are adhering. Additionally, you must send the proof of payment to the General Sub-Directorate of Inspection to continue with the procedure in accordance with the amount deposited.

The procedure will have a maximum duration of twelve months from the date of the agreement to initiate or, where applicable, from the draft agreement to initiate. After this period, it will expire, and consequently, the file will be archived; in accordance with the provisions of Article 64 of the

LOPDGDD.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On May 16, 2024, the respondent has proceeded to pay the sanction in the amount of 4,200 euros making use of the two reductions provided for in the previously transcribed Agreement to Initiate, which implies the acknowledgment of responsibility.

THIRD: The payment made, within the period granted to submit allegations regarding the opening of the procedure, entails the renunciation of any action or appeal in the administrative route against the sanction and the acknowledgment of responsibility concerning the facts referred to in the Agreement to Initiate.

FOURTH: In the Agreement to Initiate transcribed above, it was indicated that, if the infringement were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame...".

Having acknowledged the responsibility for the infringement, the imposition of the measures included in the Agreement to Initiate is appropriate.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/32

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when a pecuniary sanction and a non-pecuniary sanction can be imposed but the imposition of the latter has been justified as inappropriate, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve

the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which will be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure and their effectiveness will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the sanction. The percentage of reduction provided in this section may be increased by regulation.”

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/32

FIRST: DECLARE the termination of the procedure EXP202303565, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: ORDER PILLOW HOTELS, S.L. to notify the Agency of the adoption of the measures described in the legal grounds of the Initiation Agreement transcribed in this resolution, within a period of 6 months from the date this resolution becomes final and enforceable.

THIRD: NOTIFY this resolution to PILLOW HOTELS, S.L.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

1259-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es